

LAB 09 — NETWORK INTRUSION DETECTION: SURICATA IDS

Custom Rule Authoring, Live Traffic Detection & Alert Analysis

CySA+ Home Lab Portfolio | Alejandro W. Orellana | June 29, 2026

1. Lab Overview

This lab demonstrates network intrusion detection using Suricata 8.0.5, an open-source IDS/IPS engine used by enterprise SOCs worldwide. The lab covers installation, rule management via `suricata-update`, custom rule authoring, live traffic capture on a host interface, and alert analysis from both `fast.log` and `eve.json` outputs.

Field	Detail
Tool	Suricata 8.0.5 (IDS mode, eth0 live capture)
Monitor Interface	eth0 — 192.168.40.7/24
Target	Metasploitable2 — 192.168.40.3
Ruleset	Emerging Threats Open — 66,813 rules downloaded, 50,882 enabled
Custom Rules	3 analyst-authored rules (SID 9000001–9000003)
Alert Outputs	<code>fast.log</code> (human-readable) + <code>eve.json</code> (structured JSON)
Total Alerts	19 alerts across 3 custom rules
ATT&CK; Techniques	T1040, T1046, T1190, T1021.004

2. Environment Setup & Rule Configuration

Suricata was installed and rules updated using `suricata-update`:

```
$ sudo apt install suricata -y
$ sudo suricata-update
29/6/2026 -- 12:23:27 - -- Loaded 66813 rules.
29/6/2026 -- 12:23:27 - -- Enabled 50882 rules.
29/6/2026 -- 12:23:27 - -- Writing rules to /var/lib/suricata/rules/suricata.rules
29/6/2026 -- 12:23:51 - -- Done.
```

Configuration test confirmed all rules loaded successfully:

```
$ sudo suricata -T -c /etc/suricata/suricata.yaml -v 2>&1 | tail -5
Info: detect: 2 rule files processed. 50885 rules successfully loaded, 0 rules failed
Info: detect: 50890 signatures processed. 1281 are IP-only rules,
4505 are inspecting packet payload, 44865 inspect application layer
Notice: suricata: Configuration provided was successfully loaded. Exiting.
```

3. Custom Detection Rules — Analyst Authored

Three custom Suricata rules were authored and saved to /var/lib/suricata/rules/local.rules. Each rule demonstrates a different protocol detection capability and maps to a real-world SOC detection use case.

```
# Rule 1 – ICMP Reconnaissance Detection
alert icmp any any -> any any (msg:"ICMP Ping Detected - Lab 09"; icode:0; itype:8; sid:9000001; rev:1;)

# Rule 2 – HTTP Traffic to Target Detection
alert tcp any any -> 192.168.40.3 80 (msg:"HTTP Traffic to Metasploitable2 - Lab 09";
flow:to_server,established; sid:9000002; rev:1;)

# Rule 3 – SSH Connection Attempt Detection
alert tcp any any -> 192.168.40.3 22 (msg:"SSH Connection Attempt to Metasploitable2 - Lab 09";
flow:to_server; sid:9000003; rev:1;)
```

SID	Rule Name	Protocol	Detection Logic	SOC Use Case
9000001	ICMP Ping Detected	ICMP	itype:8 (echo request), icode:0 — matches outbound pings only	Detect network reconnaissance / host discovery
9000002	HTTP to Metasploitable2	TCP/80	flow:to_server,established — fires on active HTTP sessions only	Detect web traffic to sensitive internal hosts
9000003	SSH Connection Attempt	TCP/22	flow:to_server — fires on any TCP traffic to port 22	Detect lateral movement / remote access attempts

4. Alert Output — fast.log Analysis

Traffic was generated against Metasploitable2 using ping, curl, and ssh commands. Suricata detected all three traffic types and generated 19 alerts across the custom rules.

Raw fast.log output (all 19 alerts):

```
06/29/2026-13:05:24 [**] [1:9000001:1] ICMP Ping Detected - Lab 09 [**]
[Priority: 3] {ICMP} 192.168.40.7:8 -> 192.168.40.3:0
06/29/2026-13:05:25 [**] [1:9000001:1] ICMP Ping Detected - Lab 09 [**]
[Priority: 3] {ICMP} 192.168.40.7:8 -> 192.168.40.3:0
... (3 more ICMP alerts – 5 total, one per ping packet)

06/29/2026-13:05:39 [**] [1:9000002:1] HTTP Traffic to Metasploitable2 - Lab 09 [**]
[Priority: 3] {TCP} 192.168.40.7:54018 -> 192.168.40.3:80
... (5 more HTTP alerts – 6 total across TCP flow packets)

06/29/2026-13:05:58 [**] [1:9000003:1] SSH Connection Attempt to Metasploitable2 - Lab 09 [**]
[Priority: 3] {TCP} 192.168.40.7:39918 -> 192.168.40.3:22
... (7 more SSH alerts – 8 total across TCP handshake packets)
```

Rule SID	Alert Message	Protocol	Alerts Fired	Source → Destination
9000001	ICMP Ping Detected	ICMP	5	192.168.40.7 → 192.168.40.3:0
9000002	HTTP Traffic to Metasploitable2	TCP/80	6	192.168.40.7:54018 → 192.168.40.3:80
9000003	SSH Connection Attempt	TCP/22	8	192.168.40.7:39918 → 192.168.40.3:22
TOTAL	All custom rules	Mixed	19	3 of 3 rules triggered successfully

5. MITRE ATT&CK; Mapping

Technique ID	Name	Tactic	Suricata Detection
T1046	Network Service Discovery	Discovery	Rule 9000001 — ICMP echo requests used to discover live hosts on the network segment
T1040	Network Sniffing	Credential Access	Suricata itself operates by passively monitoring all traffic on eth0 — same technique used by attackers for credential harvesting
T1190	Exploit Public-Facing Application	Initial Access	Rule 9000002 — HTTP traffic to Metasploitable2 port 80 detects web application attack attempts against the Apache/PHP stack found in Lab 08
T1021.004	Remote Services: SSH	Lateral Movement	Rule 9000003 — SSH connection attempts to port 22 detect lateral movement and remote access attempts

6. Analyst Findings & Key Observations

IDS detects at the network layer, not the application layer: The SSH connection attempt was detected even though it failed — the key type negotiation error prevented an actual session, but Suricata fired 8 alerts on the TCP packets. This demonstrates that IDS rules trigger on network behavior, not on successful application outcomes. A failed exploit attempt is still detectable.

Multiple alerts per session is expected behavior: The HTTP curl request generated 6 alerts and the SSH attempt generated 8 alerts because Suricata fires on each packet matching the rule, not once per session. In a production SOC environment, alert aggregation and threshold tuning are used to prevent alert fatigue from high-volume rules like these.

Emerging Threats ruleset provides immediate detection coverage: suricata-update downloaded 66,813 rules from Emerging Threats Open in under 4 seconds — providing coverage for thousands of known attack signatures with no manual rule authoring required. Custom rules (local.rules) layer analyst-specific detections on top of this baseline.

Cross-lab connection — HTTP detection ties directly to Lab 08: Rule 9000002 detects HTTP traffic to Metasploitable2's port 80 — the same web server where Nikto found 27 vulnerabilities in Lab 08 including exposed phpMyAdmin, phpinfo(), and wp-config.php credentials. A production IDS rule would include HTTP content matching to detect phpMyAdmin login attempts or phpinfo() access specifically.

Key Takeaway: Suricata in IDS mode provides passive visibility into network traffic without disrupting connections. The combination of a community ruleset (50,882 Emerging Threats rules) and custom analyst rules (local.rules) is how real SOCs layer detection coverage — broad signature-based detection supplemented by environment-specific rules targeting high-value assets. IPS mode (inline, not used here) adds the ability to actively drop or reject malicious traffic.

7. IDS vs IPS — Mode Comparison

Capability	IDS Mode (This Lab)	IPS Mode (Inline)
Traffic handling	Passive — monitors copy of traffic	Inline — traffic passes through Suricata
Alert action	Alert only — logs to fast.log/eve.json	Alert + drop/reject malicious packets
Network impact	Zero — no latency added	Minor latency added per packet inspection
Missed attacks	Detects but cannot block	Can actively prevent exploitation

Suricata flag	-i eth0 (pcap mode)	-q 0 (NFQUEUE inline mode)
Rule keyword	alert	drop / reject